

Clase 273 — Seguridad de sistemas de control industrial (ICS/SCADA)

Parte: **13 — Seguridad móvil, IoT e inalámbrica** · Fuente: NIST SP 800-82 Rev. 3, ISA/IEC 62443 y *Practical IoT Hacking* (Chantzis et al.) 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

Objetivo

Entender la seguridad de los sistemas de control industrial (ICS) y SCADA que operan infraestructura crítica —agua, energía, manufactura— donde un fallo tiene consecuencias físicas. El alumno aprenderá el modelo Purdue, los protocolos industriales inseguros por diseño (Modbus, DNP3, S7), la diferencia de prioridades entre TI y OT, y practicará enumeración y análisis de protocolos contra un **simulador** de laboratorio, nunca contra sistemas en producción.

⚠️ **Nota ética y de seguridad crítica:** NUNCA escanees ni pruebes sistemas ICS/SCADA en producción; un simple escaneo puede detener procesos físicos y poner en riesgo vidas. Todo se practica en simuladores/laboratorios aislados (Conpot, GRFICS, PLCs de práctica) de tu propiedad.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Describir** el modelo Purdue y la segmentación TI/OT.
2. **Explicar** por qué los protocolos ICS carecen de autenticación y cifrado.
3. **Enumerar** dispositivos y protocolos ICS con herramientas seguras.
4. **Analizar** tráfico Modbus/DNP3 en Wireshark.
5. **Interactuar** con un PLC simulado para leer/escribir registros en laboratorio.
6. **Aplicar** controles de IEC 62443 y NIST SP 800-82 a un caso.

Temas

#	Tema	Por qué importa
1	ICS vs. TI: prioridades	Disponibilidad y seguridad física ante todo
2	Modelo Purdue y zonas	Base de la segmentación defensiva
3	Componentes: PLC, HMI, RTU, DCS	Vocabulario y roles del entorno OT
4	Protocolos (Modbus, DNP3, S7)	Inseguros por diseño
5	Enumeración segura	Cómo mirar sin romper procesos
6	Casos: Stuxnet, TRITON, Ukraine	Impacto real demostrado
7	IEC 62443 y SP 800-82	Marcos de defensa OT

Definiciones y características

- **SCADA:** sistema de supervisión y adquisición de datos que monitoriza y controla procesos distribuidos. Característica: prioriza disponibilidad y tiempo real.
- **PLC (Controlador Lógico Programable):** dispositivo que ejecuta la lógica de control de un proceso físico. Característica: acepta comandos de escritura sin autenticar en muchos protocolos.
- **Modelo Purdue:** arquitectura de referencia por niveles (0 proceso físico a 5 red corporativa). Característica: guía la segmentación entre OT y TI.
- **Modbus:** protocolo industrial simple y ubicuo. Característica: sin autenticación ni cifrado; cualquiera en la red puede leer/escribir registros.
- **DNP3:** protocolo común en servicios eléctricos/agua. Característica: más rico que Modbus pero también inseguro sin Secure Authentication.
- **Zona desmilitarizada industrial (iDMZ):** capa intermedia entre TI y OT. Característica: control de flujo estricto entre niveles Purdue.

Herramientas y preparación

- **Simuladores:** Conpot (honeypot ICS), GRFICS (planta virtual), OpenPLC, ModbusPal, PLC de práctica propio.
- **Wireshark** con dissectores Modbus/DNP3, **nmap** con scripts NSE ICS (solo contra simuladores), **pymodbus**.

```
# SOLO contra tu simulador/laboratorio
nmap -Pn -p 502 --script modbus-discover <ip_simulador>      # enumerar Modbus
python3 -c "from pymodbus.client import ModbusTcpClient as C;\n c=C('127.0.0.1',port=502);print(c.read_holding_registers(0,10).registers)"
# Captura y análisis
wireshark -k -i lo -f "tcp port 502"
```

Laboratorio guiado

1. **Levanta el laboratorio:** despliega OpenPLC/GRFICS o Conpot en una red aislada.
2. **Dibuja el modelo Purdue** del entorno simulado: ubica proceso, PLC, HMI y red.

3. **Enumera de forma segura:** con nmap contra el **simulador**, identifica el puerto 502 y usa `modbus-discover`.
4. **Analiza el protocolo:** captura tráfico Modbus en Wireshark y descompón funciones (read/write coils, holding registers).
5. **Interactúa con el PLC:** con pymodbus lee registros y, en tu simulador, escribe un valor observando el efecto en la HMI/proceso simulado.
6. **Estudia casos reales:** analiza cómo Stuxnet, la red eléctrica de Ucrania y TRITON comprometieron OT y qué controles habrían ayudado.
7. **Propón defensas:** segmentación Purdue/iDMZ, monitorización pasiva, allowlisting, IEC 62443 zonas y conductos.

Ejercicios

1. Explica tres diferencias de prioridades entre seguridad TI y OT.
2. Sitúa PLC, HMI, historiador y firewall en los niveles del modelo Purdue.
3. Enumera un PLC Modbus simulado y lista sus registros.
4. Descompón una transacción Modbus capturada indicando función y datos.
5. Escribe un registro en tu simulador y describe el impacto en el proceso.
6. Resume un incidente ICS real y los controles IEC 62443 que lo habrían mitigado.

Reto verificable

Sobre un PLC **simulado** propio, demuestra la ausencia de autenticación de Modbus: lee y modifica un holding register y observa el cambio reflejado en la HMI/proceso simulado. **Criterio de aceptación:** documentas la transacción Modbus (función, dirección, valor) con evidencia de captura, y propones al menos dos controles concretos de segmentación/monitorización que reducirían el riesgo en un entorno real.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Escaneo detiene el proceso	Nunca escanees producción; usa solo simuladores y escaneo pasivo real
Wireshark no descompone Modbus	Puerto no estándar; fuerza el disector "Decode As" TCP/502
pymodbus no conecta	Firewall/segmentación o IP/puerto erróneos; verifica el simulador
Registros vacíos	Dirección/función incorrecta; revisa el mapa de memoria del PLC
Confundir coils y registers	Tipos de datos distintos; consulta la especificación Modbus

Preguntas frecuentes

? ¿Por qué no puedo escanear un ICS como una red TI normal? Porque muchos dispositivos OT son frágiles: un escaneo agresivo puede colgar un PLC y detener un proceso físico con consecuencias graves. En OT se prioriza el análisis pasivo.

? **¿Por qué los protocolos industriales no tienen cifrado?** Se diseñaron hace décadas para redes aisladas y deterministas, priorizando latencia y fiabilidad. La convergencia TI/OT los expuso sin que su diseño evolucionara.

? **¿Qué marco debo seguir para asegurar OT?** IEC 62443 (zonas y conductos, niveles de seguridad SL) y NIST SP 800-82 son las referencias centrales para arquitectura y controles.

Referencias

- NIST SP 800-82 Rev. 3: <https://csrc.nist.gov/pubs/sp/800/82/r3/final>
- ISA/IEC 62443: <https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards>
- MITRE ATT&CK for ICS: <https://attack.mitre.org/matrices/ics/>
- Conpot: <https://github.com/mushorg/conpot> · GRFICS: <https://github.com/Fortifyd/GRFICSv2>

Siguiente clase

Clase 274 - Seguridad automotriz y bus CAN